

במפגש השני של הקורס, המרצה מיכאל המשיך להעמיק בתפקידו של ה-CISO, סקר את השחקנים המרכזיים בשוק אבטחת המידע והציג את שכבות ההגנה והאתגרים הטכנולוגיים העומדים לפתחו של הארגון.¹

להלן סיכום הנושאים המרכזיים מהשיעור:

מגמות בשוק הסייבר העולמי

- **השפעת הקורונה:** בתקופת הקורונה חלה פריחה בעולמות הסייבר בשל המעבר לעבודה מהבית, גידול בקניות אונליין ודיגיטציה של מערכות הבריאות, מה שהגדיל את מאגרי המידע והפך אותם ליעדים אטרקטיביים לתקיפה 2-5.
- **שחקניות מובילות:** המרצה סקר חברות בולטות בתחום כמו **Palo Alto Networks, Fortinet, CrowdStrike, Check Point**, ומיקרוסופט 5-7.
- **טכנולוגיות משבשות:**
- **AI (בינה מלאכותית):** נכנסת כשחקן משמעותי הן בחיפוש פגיעויות בקוד והן בבניית מערכות הגנה חכמות יותר 8-10.
- **מחשוב קוונטי:** טכנולוגיה עתידית שצפויה להפוך רבות מההצפנות הקיימות היום ללא רלוונטיות 11.

תפקיד ומבנה ה-CISO וה-InfoSec

- **מיקום ארגוני:** ה-CISO חייב להיות בדרג בכיר (C-Level/סמנכ"ל) הכפוף למנכ"ל כדי לאפשר **קבלת החלטות מהירה** ורוחבית 12, 13.
- **12 עמודי התווך של האחריות:** תחומי האחריות כוללים רגולציה (Compliance), דוקומנטציה, ניהול סיכונים, יחסים עם הנהלה, ניהול נכסים (Asset Management), עבודה עם ספקי צד שלישי, המשכיות עסקית (BCP) ועוד 14-20.
- **ארגון ה-InfoSec:** זהו גוף פנימי בארגון (ולא גוף פיתוח מוצרים) האחראי על אבטחת המידע השוטפת והגנה על נכסי הארגון 21-23.

שכבות הגנה ומושגי יסוד

1. **שלושת ממדי אבטחת המידע (CIA):**
2. **זמינות (Availability):** המידע חייב להיות נגיש 24/7, 24, 25.
3. **שלמות (Integrity):** שמירה על כך שהמידע לא ישונה בדרך 24, 26.
4. **סודיות (Confidentiality):** הבטחת חשיפת המידע למורשים בלבד, לרוב באמצעות הצפנה 24, 27.
5. **שכבות הגנה במערכת:** ההגנה נבנית מהליבה החוצה: מהדאטה (Data), דרך האפליקציה (WAF, הצפנות), המארחים (Endpoints), הרשת (Network) ועד למעגלים החיצוניים הכוללים ענן ו-IoT 28-32.
6. **White Box לעומת Black Box:** במערכת White Box יש גישה מלאה לקוד, בעוד שב-Black Box מתמקדים רק בקלט ובפלט מבלי להכיר את הפעולה הפנימית 33-35.

אסטרטגיות התמודדות עם איומים

- **ניהול סיכונים:** המטרה היא לא למנוע 100% מהאיומים (דבר בלתי אפשרי), אלא למפות את הנכסים הקריטיים ולהבין על מה כל איום משפיע 36, 37.
- **סיגמנטציה (Segmentation):** חלוקת המערכת לחלקים המאפשרת **בידוד של אזור שנפרץ** כדי למנוע את השבתת הארגון כולו 38-40.
- **המשכיות עסקית (BCP):** תכנון מראש למצבי אסון (כגון פריצה או אסון טבע) כדי להבטיח את המשך קיום הארגון 41, 42.

איומים נפוצים

- **DDoS:** התקפות מבזרות למניעת שירות שהתפתחו מפינגים פשוטים לנפחי מידע אדירים (מאות ג'יגה בשנייה) 43-45.
- **טעויות הגדרה (Misconfiguration):** איום משמעותי הנובע מהגדרות לא נכונות של פיירוולים או שרתים, במיוחד בענן 46, 47.
- **חוסר בעדכונים:** כ-8% מהפגיעויות נובעות מכך שמשתמשים וארגונים אינם מעדכנים גרסאות תוכנה בזמן 48, 49.